

LEARNSPHERE EDTECH

NIST CYBERSECURITY FRAMEWORK (CSF) 2.0

Gap Assessment & Remediation Roadmap

Existing / Ad Hoc Cybersecurity Posture Assessment

DOCUMENT ID	LS-NIST-001
VERSION	1.0
ASSESSMENT DATE	04-Sep-2026
FRAMEWORK	NIST Cybersecurity Framework 2.0
ORGANIZATION	LearnSphere EdTech

Prepared By

Mr. Meejan Shaikh | GRC Analyst
Information Security Management Team

1. Document Control

FIELD	DETAILS
Document ID	LS-NIST-001
Document Title	NIST CSF 2.0 Gap Assessment & Remediation Roadmap
Organization	LearnSphere EdTech
Assessment Basis	Existing/ad hoc cybersecurity practices; not a blank-slate assessment.
Assessment Method	Current vs Target profile-style assessment supported by an internal 0–4 maturity scale.

Approval

ROLE	NAME / DESIGNATION	SIGNATURE	DATE
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	04/09/2026
Reviewed By	Information Security Manager	_____	04/09/2026
Approved By	CISO	_____	04/09/2026

2. Executive Summary

This assessment evaluates LearnSphere EdTech’s existing cybersecurity posture against relevant outcomes in NIST CSF 2.0. It assumes security practices already exist in an ad hoc form and assesses how consistently those practices are governed, implemented, evidenced, measured, and improved.

The assessment focuses on children’s data, parental-consent governance, data minimization, and access controls over student records. Protect is the highest priority because student-record access governance requires the strongest target state.

FUNCTION	CURRENT	TARGET	GAP	PRIORITY
Govern (GV)	1.75	3.00	1.25	High
Identify (ID)	1.75	3.00	1.25	High
Protect (PR)	1.75	3.25	1.50	Critical
Detect (DE)	1.75	3.00	1.25	High
Respond (RS)	2.00	3.00	1.00	Medium-High
Recover (RC)	1.75	3.00	1.25	Medium

Overall current maturity: 1.79 / 4.00 Target: 3.04 / 4.00 Gap: 1.25

3. Assessment Methodology

NIST CSF 2.0 is outcome-based rather than a conventional pass/fail checklist. This assessment uses selected Categories/Subcategories to build a Current Profile view and compare it with a Target Profile. The internal 0–4 scale is a project scoring convention, not an official NIST maturity scale.

0 Not Performed — no credible evidence. **1** Ad Hoc — inconsistent or reactive. **2** Repeatable — some consistency, but incomplete documentation/coverage/measurement. **3** Defined — documented, assigned, consistently implemented. **4** Managed/Optimized — measured, reviewed, and continuously improved.

Assessment assumptions: LearnSphere operates a cloud-hosted LMS primarily on AWS and processes sensitive personal information for students, teachers, school administrators, and employees. Existing IAM, logging, backup, endpoint, application-security, and incident-response practices are assumed to exist but not to be uniformly mature.

4. Govern (GV)

GV.OC-03	Current 1	Target 3	Gap 2.00
NIST outcome focus GV.OC-03			
Assessment justification Legal/regulatory and privacy obligations are recognized, but children's-data and parental-consent requirements are not consistently translated into documented operational requirements.			
Recommended action Create a children's-data requirements register mapped to owners, processes, evidence and review cadence.			
GV.RM-01	Current 2	Target 3	Gap 1.00
NIST outcome focus GV.RM-01			
Assessment justification Risk assessment exists, but product or data-processing changes do not consistently trigger a structured cybersecurity/privacy review.			
Recommended action Integrate security and privacy risk review into product changes and new data processing.			
GV.RR-02	Current 2	Target 3	Gap 1.00
NIST outcome focus GV.RR-02			
Assessment justification Security responsibilities exist, but ownership for children's-data governance, consent and minimization is not consistently formalized.			
Recommended action Assign accountable owners and a RACI across Privacy, Product, Engineering, Security and Operations.			
GV.PO-01	Current 2	Target 3	Gap 1.00
NIST outcome focus GV.PO-01			
Assessment justification Existing policies provide a baseline, but children's-data requirements do not consistently translate into collection, consent, minimization, access and retention rules.			
Recommended action Update policies and standards with explicit children's-data requirements and exception handling.			

5. Identify (ID)

ID.AM-02	Current 2	Target 3	Gap 1.00
NIST outcome focus ID.AM-02			
Assessment justification Asset information exists, but systems/services are not consistently linked to the student-data types they process.			
Recommended action Map applications, services, databases and cloud components to data categories and business owners.			
ID.AM-07	Current 1	Target 3	Gap 2.00
NIST outcome focus ID.AM-07			
Assessment justification Sensitive student-data inventory and metadata are incomplete, limiting visibility into where designated children's data is stored, processed and retained.			
Recommended action Create a designated student-data inventory with owner, purpose, source, location, sensitivity, retention and sharing metadata.			
ID.RA-04	Current 2	Target 3	Gap 1.00
NIST outcome focus ID.RA-04			
Assessment justification Risk assessment is performed, but changes to student-data processing do not consistently trigger formal cybersecurity/privacy impact assessment.			
Recommended action Introduce a processing-change risk trigger and minimum assessment criteria.			
ID.RA-05	Current 2	Target 3	Gap 1.00
NIST outcome focus ID.RA-05			
Assessment justification Technical risk is considered, but data-minimization risk is not consistently captured as a distinct risk factor.			
Recommended action Add unnecessary collection, excessive retention and unnecessary access as explicit risk factors.			

6. Protect (PR)

PR.AA-05	Current 2	Target 4	Gap 2.00
NIST outcome focus PR.AA-05			
Assessment justification IAM controls exist, but student-record entitlement governance is not consistently mature enough to demonstrate continuous least privilege and separation of duties.			
Recommended action Implement quarterly student-record access certification, privileged recertification, exception tracking and evidence-linked closure.			
PR.AA-03	Current 2	Target 3	Gap 1.00
NIST outcome focus PR.AA-03			
Assessment justification Authentication controls exist, but requirements vary by system and access path and are not consistently standardized by student-record sensitivity.			
Recommended action Define minimum authentication requirements by system/data risk, with stronger controls for privileged access.			
PR.DS-01	Current 2	Target 3	Gap 1.00
NIST outcome focus PR.DS-01			
Assessment justification Encryption and access restrictions are part of the environment, but protection is not consistently mapped across the student-data lifecycle and all repositories.			
Recommended action Create a student-data protection matrix covering databases, backups, endpoints, exports, logs and third parties.			
PR.DS-10	Current 1	Target 3	Gap 2.00
NIST outcome focus PR.DS-10			
Assessment justification Controls exist around application/database access, but retention and disposal are not consistently enforced to reduce unnecessary exposure.			
Recommended action Define retention/disposal rules by data category and implement evidence-backed deletion controls.			

7. Detect (DE)

DE.CM-01	Current 2	Target 3	Gap 1.00
NIST outcome focus DE.CM-01			
Assessment justification Security monitoring is present, but coverage for critical assets and student-data environments is not consistently measured.			
Recommended action Define monitoring coverage KPIs and maintain an inventory-to-log-source mapping.			
DE.CM-06	Current 2	Target 3	Gap 1.00
NIST outcome focus DE.CM-06			
Assessment justification Third-party expectations exist, but monitoring evidence and escalation expectations are not consistently defined for all critical providers.			
Recommended action Define provider monitoring, evidence and escalation requirements.			
DE.AE-02	Current 2	Target 3	Gap 1.00
NIST outcome focus DE.AE-02			
Assessment justification Alert investigation occurs, but quality is not consistently measured through MTTD/MTTI or standardized investigation records.			
Recommended action Introduce investigation KPIs and standard investigation records.			
DE.AE-04	Current 1	Target 3	Gap 2.00
NIST outcome focus DE.AE-04			
Assessment justification Correlation between IAM events, student-record access and application activity is not consistently defined.			
Recommended action Develop correlation use cases for privileged access and student-record anomalies.			

8. Respond (RS)

RS.MA-01	Current 2	Target 3	Gap 1.00
NIST outcome focus RS.MA-01			
Assessment justification Incident handling exists, but severity and escalation do not consistently distinguish incidents involving children's data or student-record exposure.			
Recommended action Create severity criteria explicitly classifying children's-data incidents.			
RS.AN-03	Current 2	Target 3	Gap 1.00
NIST outcome focus RS.AN-03			
Assessment justification Investigation occurs, but unauthorized student-record access lacks a fully standardized evidence-analysis workflow.			
Recommended action Create a playbook covering IAM, application, database and access evidence.			
RS.CO-02	Current 2	Target 3	Gap 1.00
NIST outcome focus RS.CO-02			
Assessment justification Communication roles exist, but student-data incident escalation and privacy/customer decisions are not consistently documented end-to-end.			
Recommended action Define communications RACI, escalation thresholds and notification decision points.			
RS.MI-01	Current 2	Target 3	Gap 1.00
NIST outcome focus RS.MI-01			
Assessment justification Containment practices exist, but predefined playbooks for compromised student records are incomplete.			
Recommended action Develop playbooks for compromised accounts, unauthorized access and data exfiltration.			

9. Recover (RC)

RC.RP-01	Current 2	Target 3	Gap 1.00
NIST outcome focus RC.RP-01			
Assessment justification Recovery capability exists, but testing is not consistently scenario-based around ransomware, database compromise or student-data loss.			
Recommended action Conduct documented recovery exercises using LMS/student-data scenarios.			
RC.RP-03	Current 2	Target 3	Gap 1.00
NIST outcome focus RC.RP-03			
Assessment justification Recovery priorities are known in part, but RTO/RPO alignment and dependency documentation are not consistently maintained.			
Recommended action Document dependencies, RTO/RPO, owners and test evidence.			
RC.CO-02	Current 2	Target 3	Gap 1.00
NIST outcome focus RC.CO-02			
Assessment justification Service-disruption communications are considered, but student/customer recovery communication requirements are not fully defined.			
Recommended action Establish recovery communication criteria, ownership and customer notification paths.			
RC.IM-01	Current 1	Target 3	Gap 2.00
NIST outcome focus RC.IM-01			
Assessment justification Lessons learned are not systematically converted into tracked improvement actions with closure evidence.			
Recommended action Create a lessons-learned register linked to corrective actions and management review.			

10. Prioritized Gap Register

ID	GAP	FUNCTION	PRIORITY	TIMELINE	REMEDIATION
GAP-01	Children's-data requirements	GV	High	0–30	Requirements register with owners and evidence.
GAP-02	Parental-consent governance	GV	Critical	0–30	Consent requirements, ownership, evidence, withdrawal and review.
GAP-03	Student-data inventory	ID	High	0–90	Designated-data inventory and system/data mapping.
GAP-04	Data minimization	ID	High	0–90	Minimization checks in product/data risk assessments.
GAP-05	Student-record access reviews	PR	Critical	0–30	Quarterly certification, exceptions and closure evidence.
GAP-06	Privileged access governance	PR	Critical	0–30	Privileged recertification and dormant-account controls.
GAP-07	Monitoring coverage	DE	High	31–90	Coverage KPIs, log-source mapping and correlation.
GAP-08	Children's-data incident playbook	RS	High	31–90	Playbooks for unauthorized access and data exfiltration.
GAP-09	Recovery testing	RC	Medium	91–180	Scenario-based recovery tests and RTO/RPO validation.
GAP-10	Lessons learned	RC	Medium	91–180	Tracked improvement actions and management review.

11. Remediation Roadmap

PHASE	OBJECTIVE	KEY DELIVERABLES	PRIMARY OWNERSHIP
0–30 Days	Governance & immediate risk reduction	Children's-data ownership; parental-consent requirements; student-record access review; privileged recertification; dormant-account checks; excessive-collection review.	CISO / Security / Privacy / Product / IAM
31–90 Days	Standardization & visibility	Student-data inventory; minimization standard; access certification; authentication standard; incident playbook; monitoring KPIs; application-to-data mapping.	Security / Engineering / Product / Privacy
91–180 Days	Measurement & resilience	Recovery exercises; RTO/RPO mapping; security metrics; product/change risk integration; third-party monitoring; lessons learned; Target Profile reassessment.	Security / IT / Engineering / Business Owners

12. Conclusion

LearnSphere EdTech is not starting from zero. The assessment indicates an existing security foundation, but several practices remain at an ad hoc or repeatable stage. The most significant maturity gap is the ability to consistently govern and evidence protection of children's data, particularly parental consent, data minimization and student-record access.

The roadmap prioritizes high-impact governance and access improvements within 30 days, standardization during 31–90 days, and measurable resilience and continuous improvement during 91–180 days.

Approval

ROLE	NAME	SIGNATURE	DATE
Prepared By	Mr. Meejan Shaikh	_____	04/09/2026
Reviewed By	Information Security Manager	_____	04/09/2026
Approved By	CISO	_____	04/09/2026